

Enterprise Cybersecurity Risk Assessment

Project Overview | GRC Portfolio Project

Dhriti Pandya

BS Applied Computer Science - Cybersecurity
University of South Carolina Aiken | August 2026

Why I Built This Project

I created this project to get hands-on experience with how cybersecurity risks are identified, scored, documented, and treated in a GRC environment. I used BlueWave Retail Solutions, a fictional retail and e-commerce company, so I could work through the risk assessment process without using information from a real organization.

What I Did

I started by defining BlueWave's business environment, security objectives, assessment scope, and technology environment. I then created an asset inventory with 10 systems that would be important to the company's daily operations.

For each asset, I identified a possible cybersecurity threat and a vulnerability that could make that threat more likely or more damaging. I used those threat and vulnerability pairs to build the risk register.

I scored each risk using a 5x5 Likelihood x Impact method. After calculating the inherent risk, I recommended security controls and estimated the residual risk that could remain after those controls were implemented.

Main Parts of the Assessment

- Asset inventory and asset criticality
- Threat and vulnerability identification
- 5x5 likelihood and impact risk scoring
- Enterprise risk register
- Inherent and estimated residual risk
- Risk owners and remediation priorities
- Security control recommendations
- Risk treatment recommendations
- NIST Cybersecurity Framework mapping

Key Finding

The highest inherent risk in my assessment was ransomware affecting the backup systems. In the scenario, the backups were connected to the production environment, which could allow ransomware to affect both production data and backup copies. I scored this risk as 20 (Critical). My recommended controls were offline or immutable backups along with regular restoration testing.

What I Learned

One of the main things I learned from this project is that a security control does not automatically remove risks. Controls can lower the likelihood or impact, but some risks can remain. That is why I added residual risk to the risk register instead of treating the recommended controls as if they completely solved the problem.

I also learned that GRC work is not only about identifying technical problems. The risk has to be connected to the business, assigned to an owner, prioritized, and explained in a way that helps the organization decide what should be addressed first.

NIST CSF Connection

At the end of the assessment, I mapped BlueWave's security activities to the five NIST Cybersecurity Framework functions: Identify, Protect, Detect, Respond, and Recover. This helped me connect individual controls and risk activities to a broader cybersecurity framework.

Skills Practiced

- Cybersecurity risk assessment
- Risk register development
- Asset, threat, and vulnerability analysis
- Inherent and residual risk analysis
- Security control selection
- Risk treatment and prioritization
- NIST Cybersecurity Framework mapping
- Communicating cybersecurity risk in business terms

Disclaimer

BlueWave Retail Solutions is a fictional organization created for educational and portfolio purposes. No confidential or proprietary information from a real organization was used in this project.